

CYBER PREPAREDNESS & RANSOMWARE THREAT ASSESSMENT

The Gentlemen Ransomware-as-a-Service | OmniRoute
Logistics

Portfolio Case Study - AfricaHackon Academy Capstone

September 2026

42

Countries

1,800+

Enterprise clients

600k+

Shipment records/day

Collaborative capstone project - Squad 4

Portfolio focus: threat modelling, ATT&CK mapping, detection engineering, incident response, and resilient recovery.

1. Project Overview

Turning a ransomware scenario into a board-ready preparedness and response strategy

This capstone assessed how a multinational logistics organization could prevent, detect, contain, and recover from an intrusion by The Gentlemen, a financially motivated ransomware group. The scenario linked technical attacker behavior to operational consequences across shipment visibility, customs processing, warehouse operations, customer commitments, and regulatory exposure.

PROJECT OBJECTIVE

Build a defensible preparedness strategy that assumes prevention can fail, limits attacker movement, creates detection opportunities before encryption, and preserves a trusted path to recovery.

Scope and frameworks

Area	What the project covered
Threat characterization	Adversary class, motivation, persistence, defense evasion, and business impact.
Threat mapping	MITRE ATT&CK techniques across initial access, credential abuse, lateral movement, persistence, exfiltration, impact, and recovery inhibition.
Preparedness	Architectural Resilience aligned to NIST CSF 2.0 and NIST SP 800-61 Rev. 3.
Detection engineering	Sysmon Event IDs 1 and 11 for scheduled-task persistence, process masquerading, and artifact correlation.
Incident response	Prioritized first-24-hour containment and recovery-protection strategy.

My portfolio contribution

- Collaborated on the board-ready threat assessment and recommendations for the OmniRoute scenario.
- Performed detection-engineering analysis around Sysmon EID 1 (ProcessCreate) and EID 11 (FileCreate), including OriginalFileName, command-line, parent-process, user/session, and hash context.
- Helped develop and defend a prioritized first-24-hour ransomware response strategy during a live executive-style panel presentation.

2. Threat Model and Business Exposure

The Gentlemen was classified as a Cyber Breach & Organisational Disruption adversary because the scenario goes beyond initial compromise: stolen credentials, lateral movement, defense evasion, data theft, encryption, and recovery disruption can turn a single foothold into a multi-region operational incident.

Attack behavior	Business implication
Fortinet edge exploitation / stolen credentials	Creates an initial foothold and potential privileged access.
RDP, WMI, PowerShell, valid accounts	Enables lateral movement and remote administration across connected systems.
Scheduled tasks / registry persistence	Maintains access across reboots and partial cleanup.
EDR impairment / logging changes	Reduces visibility and complicates forensic investigation.
Data exfiltration + encryption	Creates double-extortion pressure and long-lasting confidentiality impact.
Recovery inhibition	Extends downtime and reduces trusted restoration options.

CORE RISK

For OmniRoute, the most important risk is not one encrypted endpoint. It is an attack that spreads across identity, shared infrastructure, logistics systems, and recovery services at the same time.

Business impact areas

- Operational disruption: shipment visibility, customs workflows, warehouse systems, and customer portals could become unavailable across regions.
- Data exposure: client, cargo, financial, and operational information could be stolen before encryption and remain exposed after systems are restored.
- Regulatory and contractual pressure: cross-border notification, investigation, customer assurance, and SLA consequences may occur in parallel with technical containment.
- Recovery pressure: compromised identities, management systems, or online backups can make a clean restore much harder than simply recovering files.

3. MITRE ATT&CK Mapping and Control Strategy

The project mapped observed and scenario-relevant TTPs to practical preventive and detective controls. The goal was to show how attacker behavior translates into engineering priorities rather than treating ATT&CK as a checklist.

ID	Technique	Prevent	Detect
T1190	Exploit public-facing application	Patch/harden Fortinet, restrict admin exposure	Fortinet logs, asset exposure, suspicious admin activity
T1078.002	Valid domain/VPN accounts	MFA, PAM, separate admin accounts, rotate credentials	Unusual logins, privileged access, VPN anomalies
T1059.001	PowerShell	Least privilege, script controls	Command lines, PowerShell logs, EDR behavior
T1047	WMI	Restrict remote WMI and admin paths	wmioprse.exe chains, remote execution patterns
T1053.005	Scheduled Task	Limit admin rights, application control	Sysmon EID 1 + EID 11, task logs
T1562.001	Impair Defenses	Vulnerable-driver blocking, tamper protection	Driver loads, EDR health, security-service stops
T1484.001	Group Policy Modification	Protect DCs, controlled GPO changes	GPO and directory-service monitoring
T1021.001	RDP	Disable/restrict, MFA, jump hosts	RDP logons and abnormal source/destination patterns
T1486	Data Encrypted for Impact	Segmentation, application control, protected backups	Mass file changes, ransomware behavior, share-write anomalies
T1490	Inhibit System Recovery	Immutable/offline backups, separate recovery credentials	Backup-service stops, shadow-copy deletion, repository deletion attempts

4. Detection Engineering: Scheduled-Task Persistence

A key detection exercise focused on a scheduled task named WindowsUpdateService launching C:\ProgramData\svchost.exe at system boot. The analysis used complementary Sysmon telemetry so the detection would not depend on a single executable name or event.

SUSPICIOUS PATTERN

OriginalFileName = schtasks.exe | Task = WindowsUpdateService | Trigger = ONSTART | Payload = C:\ProgramData\svchost.exe

Why EID 1 and EID 11 are complementary

Telemetry	What it provides	Coverage gap	Best use
Sysmon EID 1 - ProcessCreate	Process path, command line, user, parent process, hashes, process/session identifiers.	May miss task creation through PowerShell APIs, COM, or other tooling that does not invoke the matched binary.	Explain how the task was created and who/what initiated it.
Sysmon EID 11 - FileCreate	Evidence that a task artifact was written in a scheduled-task directory.	Does not carry the full command/session context and can include legitimate activity.	Confirm that persistence was actually created.
Correlation	Combines process behavior, artifact creation, and user/session context.	Requires consistent collection and accurate event timing.	Raise a higher-confidence alert from multiple signals.

Triage fields that matter

- Image + OriginalFileName: identify unusual paths and simple masquerading of renamed utilities.
- CommandLine: look for the task name, ONSTART trigger, SYSTEM execution, and suspicious payload path.
- ParentImage / ParentCommandLine: connect task creation to PowerShell, WMI, cmd.exe, remote services, or encoded scripts.
- User / ParentUser / IntegrityLevel: identify privileged or unexpected execution context.
- Hashes + ProcessGuid / ParentProcessGuid: validate binaries and correlate follow-on file, network, registry, and process activity.

5. First 24 Hours: Ransomware Incident Response

The response strategy was designed around containment before restoration. The key principle was to secure identity, management systems, and recovery infrastructure before reconnecting services.

Window	Priority	Actions
0-2h	Secure the edge	Restrict Fortinet management access; preserve logs and configurations; start scoping affected systems.
2-6h	Cut off access	Revoke sessions; rotate VPN/admin credentials; disable compromised accounts and tokens.
6-12h	Protect recovery	Lock down backup controls; protect Tier-0 identity; separate recovery credentials from production.
12-18h	Contain movement	Restrict RDP/WMI/WinRM/SMB; isolate affected hosts or segments; preserve volatile evidence.
18-24h	Hunt the chain	Hunt scheduled tasks, registry persistence, GPO abuse, exfiltration, EDR health issues, and touched systems.

RESPONSE PRINCIPLE

Contain first. Do not restore until identity, management systems, and backups are trusted. Restoring too early can reintroduce the attacker.

Executive coordination

- Treat suspected activity as a Severity-1 incident with one incident commander, clear technical/business leads, and out-of-band communications.
- Preserve evidence early and involve legal, privacy, regulatory, customer-communications, insurance, and external DFIR stakeholders as needed.

6. Preparedness Posture: Architectural Resilience

The recommended posture was Architectural Resilience: design the environment so that one compromise does not spread easily, detection happens before ransomware deployment where possible, and recovery does not depend on already-compromised production systems.

Resilience pillar	Key controls	Outcome
Edge exposure & identity	Patch Fortinet; restrict admin access; enforce MFA; rotate credentials; remove stale accounts.	Reduce likely entry points and credential abuse.
Segmentation & privilege boundaries	Separate critical systems; tightly control admin traffic; use PAM/PAWs or jump hosts.	Limit lateral movement and blast radius.
Threat-informed detection	Monitor EDR health, Fortinet, AD/GPO, Sysmon, PowerShell/WMI, and outbound traffic.	Detect suspicious activity before encryption.
Recovery architecture	Immutable/offline backups; separate recovery credentials; clean-room procedures; restore testing.	Keep recovery trustworthy when production is compromised.
Incident command & coordination	Severity-1 playbook; out-of-band comms; DFIR support; regulator and customer contacts.	Accelerate decisions and reduce response friction.
Continuous validation	ATT&CK-aligned detection tests; tabletop, purple-team, and recovery exercises.	Prove controls work in practice.

PREPAREDNESS PRINCIPLE

Assume prevention may fail. Harden the edge, detect early, limit movement, and recover from trusted systems.

7. Prioritized Roadmap

Window	Priority actions
0-7 days	Review all Fortinet exposure and signs of prior compromise; restrict management access; rotate credentials; hunt for follow-on activity.
8-30 days	Centralize logs; validate EDR coverage; deploy Sysmon to critical systems; review privileged accounts/GPOs; separate backup administration.
31-60 days	Restrict RDP/WinRM/WMI/SMB; tighten admin paths; block vulnerable drivers; test ATT&CK-aligned detections and host isolation.
61-90 days	Run clean recovery exercise; restore AD and a critical logistics service; conduct ransomware tabletop; measure RTO/RPO.
3-6 months	Expand segmentation; strengthen PAM and admin boundaries; reduce standing privilege; extend telemetry across regions.
6-12 months	Expand immutable backup coverage; run purple-team and cross-region exercises; track unresolved risks through governance.

Skills demonstrated

- Ransomware threat modelling and business-impact translation
- MITRE ATT&CK mapping and TTP-to-control design
- Sysmon-based detection engineering and multi-signal correlation
- Incident response prioritization and first-24-hour containment planning
- Identity, segmentation, EDR, logging, backup, and recovery architecture
- Executive communication and board-level risk framing

8. Project Artifacts, Collaboration, and References

Collaboration

This was a collaborative AfricaHackon Academy capstone completed by Squad 4. The original report credits Grace Weyama, Andrew Kiema, Arcel Mukadi Kabamba, Benard Emmanuel Kariuki, David Mwangi, Denis Kyalo Ndemwa, Gatanna Gachiri Waruinge, Joseph Kirutu, and Tiffany Murithi. This portfolio edition preserves the team nature of the work while highlighting the detection-engineering and incident-response components represented on my resume.

Repository artifacts

Artifact	Purpose
README.md	Portfolio overview, technical highlights, methodology, and repository navigation.
Portfolio_Case_Study.pdf	Polished recruiter/hiring-manager friendly case study.
Original_Report.pdf	Full academic/team report with detailed references, ATT&CK mapping, and roadmap.
Original_Presentation.pptx	Executive-style presentation used for the capstone defense.

Primary frameworks and references used in the original report

- MITRE ATT&CK Enterprise techniques, including T1053.005 Scheduled Task/Job and T1036 Masquerading.
- NIST Cybersecurity Framework (CSF) 2.0.
- NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cybersecurity Risk Management.
- CISA #StopRansomware guidance and Known Exploited Vulnerabilities catalog.
- Fortinet PSIRT guidance for CVE-2024-55591, plus threat intelligence cited in the original capstone report.

Portfolio note: OmniRoute is an academic scenario used to demonstrate cyber preparedness, detection engineering, incident response, and resilient recovery thinking. This portfolio case study is not a production security assessment of a real organization.